

Google Play Compliance Audit

DecisionOS Android app (Capacitor build) · audited against the Google Play Developer Program Policy

App	DecisionOS · <code>com.decisionos.app</code> · v1.0.1 (versionCode 2)
Build	Capacitor 8.5 · minSdk 24 · targetSdk / compileSdk 36 · bundled web assets (no remote <code>server.url</code>)
Scope	Capacitor Android app in <code>frontend/</code> + the backend it talks to. The Flutter app (<code>mobile/</code>) was not reviewed.
Rulebook	"Developer Program Policy – Play Console Help" (PDF supplied). Section names below are that PDF's headings.
Date	8 October 2026 · repo branch <code>karma-merge</code> @ <code>256a7676</code>

Verdict: NOT ready to submit

Five issues are likely to cause rejection. None of them is about Android permissions — the manifest is clean. The problems are: no way to report AI output, no moderation of user content, account deletion that leaves data behind, voice/website data sent to AI providers before consent, and a privacy policy that doesn't match the code.

5
Critical — likely rejection

11
Warnings — review risk

11
Areas already compliant

44
Pre-submission checklist items

Findings at a glance

ID	Finding	Severity	PDF section
C1	No in-app way to report or flag AI-generated output	Critical	AI-Generated Content
C2	User content has no terms, no report, no block; the demo workspace is publicly writable	Critical	User Generated Content
C3	Account deletion leaves push tokens, sessions, logs and other user rows behind	Critical	Account Deletion Requirement; Privacy Policy
C4	Signup sends voice and website data to AI providers before AI consent	Critical	User Data; Prominent Disclosure & Consent
C5	Privacy policy omits processors and the developer entity; Data Safety notes are stale	Critical	Privacy Policy; Data safety section
W1	In-app copy points users to off-Play plan upgrades	Medium	Payments §2, §4
W2	Platform-admin portal (incl. billing) shipped hidden in the app	Medium	Deceptive Behavior §5
W3	Notification permission asked at sign-in with no explanation	Medium	Permissions and APIs
W4	Unused VIBRATE permission from <code>@capacitor/haptics</code>	Low	Permissions and APIs
W5	No point-of-use disclosure that voice recordings are stored and transcribed by a third party	Medium	User Data; Prominent Disclosure
W6	Finance features require the Financial features declaration	Medium	Financial Services
W7	18+ stated only in the privacy policy	Low	Families – Target Audience

W8	PostHog / Sentry could switch on and break declarations	Medium	Data safety section
W9	Demo workspace may show strangers' content to reviewers	Medium	User Generated Content
W10	FileProvider exposes all external storage	Low	Device and Network Abuse
W11	"WebView wrapper" minimum-functionality risk	Low	Spam, Functionality & UX

1. Critical violations (high risk)

C1 — No way to report AI output inside the app

Rule	<i>AI-Generated Content</i> : apps that generate content with AI " <i>must contain in-app user reporting or flagging features</i> " that work without leaving the app.
Finding	Dex chat and voice, Company Brain answers, AI execution plans, the AI bill reader and the signup AI interview all show AI-generated text. None has a report/flag control and there is no "AI can be wrong" notice.
Evidence	<code>useDexCapture.js</code> , <code>routers/brain.py</code> , <code>routers/tasks.py</code> , <code>routers/ledger.py</code> , <code>routers/signup.py</code> — no report endpoint or UI exists.
Fix	Add a "Report" control on every AI output, stored server-side (prompt, output, user, time) and reviewed by you. Add an "AI can make mistakes" line.

C2 — User content has no terms, no report and no block

Rule	<i>User Generated Content</i> requires: • users accept terms of use before creating content; • objectionable content is defined and banned; • in-app reporting of content and users — even for apps "<i>exclusively used within a specific school or company</i>"; • blocking for one-to-one features (direct messages, tagging, mentioning).
Finding	• Workspace members see each other's tasks, decisions, comments, notes and files. • No terms of service exists in the repo; no report or block feature exists. • The shared "Sharma" demo workspace is open to anyone via "Try DecisionOS" with a password (<code>demo1234</code>) hard-coded in the app. Nothing makes it read-only, so whatever one visitor writes, every other visitor sees — public user content with zero moderation.
Evidence	<code>Login.js:23-28</code> , <code>161-163</code> , <code>515</code> ; <code>bootstrap/seed.py:20</code> ; no <code>is_demo</code> guard outside <code>seed.py</code> .
Fix	Write ToS + acceptable-use policy and require acceptance at signup and invite acceptance. Add Report on comments/tasks/decisions/notes and Report/Block on users. Make the demo read-only or a per-visitor sandbox.

C3 — Account deletion leaves user data behind

Rule	<i>Account Deletion Requirement / Privacy Policy</i> : "delete all associated user data"; no "difficulties or hidden steps"; freezing is not deletion.
Finding	• <code>device_tokens</code> (push token linked to the user ID) is never deleted, and is missing from <code>TENANT_COLLECTIONS</code> in <code>services/tenant_wipe.py</code>. • The app unregisters the push token only after the session is revoked, so that call fails. • Not in the wipe list: <code>sessions</code> (IP, user agent), <code>audit_log</code>, <code>ai_calls</code>, <code>support_tickets</code>, <code>onboarding_drafts</code>, <code>crm_activities</code>, <code>billing_events</code>, login-attempt records. The policy only says security logs are kept "for a limited period". • An owner of a workspace with other members cannot delete their account and is given no way forward.
Evidence	<code>routers/account.py:139-227</code> ; <code>services/tenant_wipe.py:19-44</code> ; <code>DeleteAccount.js:46</code> ; <code>lib/native/push.js:104-113</code> .
Fix	Delete <code>device_tokens</code> server-side in <code>delete_account</code> and add it to the wipe list. Delete or anonymise each listed collection per user, or state a retention period. Offer ownership transfer or workspace deletion to owners.

C4 — Voice and website data go to AI providers before consent

Rule	<i>User Data</i> : rules apply to "third-party AI integrations"; consent "must be granted by the user before your app can begin to collect". Microphone data is personal and sensitive.
Finding	AI consent is recorded only when the user presses "Enter DecisionOS" at the end of signup. Before that, signup has already sent the user's voice to OpenAI/Sarvam for speech-to-text, run the AI interview and run the AI website analysis. The app's own HTTP 451 consent gate is skipped for exactly those calls.
Evidence	<code>routers/signup.py:322-620</code> ; <code>services/ai_consent.py:93</code> ; <code>BuildReveal.js:1008-1025</code> .
Fix	Move the consent step to the start of signup: a disclosure naming the data and providers, then an explicit "I agree" tap, before any audio or URL leaves the device.

C5 — The privacy policy doesn't match what the app does

Rule	<i>Privacy Policy</i> : name "any parties with which any personal or sensitive user data is shared" and include developer information. <i>Data safety section</i> must be consistent with the privacy policy.
Finding	• Missing from <code>Privacy.js</code>: Firebase/FCM, Voyage and Qdrant (embeddings), Gmail SMTP and Resend (email), Cloudflare Turnstile and hCaptcha, Sentry, Twilio (SMS fallback). • Still lists Google Fonts, which the app no longer loads. • No legal entity is named; the store-listing developer name must appear (or the app must be named). • <code>docs/PRIVACY.md</code> (your Data Safety notes) still says there is no push and no FCM.
Fix	Rewrite the policy per Section 3 below, host it at a public URL and link it from Signup.

2. Warnings and grey areas (medium risk)

W1 — Pointing users to off-Play payment Payments \$2, \$4

Paid plans unlock seats and AI quota and are bought outside the app via Razorpay. Two messages nudge upgrades: "or straight away on a bigger plan" (`lib/aiLimit.js:43`) and "ask us to add seats" (`Team.js:452`). The PDF lists "business productivity software" as needing Play Billing and bans leading users elsewhere through "messaging... or other calls to action". It lists no B2B or consumption-only exemption. **Fix:** replace with neutral copy (e.g. "Contact your workspace admin") or adopt Play Billing.

W2 — Hidden admin portal shipped in the app Deceptive Behavior \$5

The platform-admin `/admin` portal, including `BillingSection`, is in the Android bundle. Behavior Transparency forbids "hidden, dormant, or undocumented features". **Fix:** exclude it from the Capacitor build.

W3 — Notification permission asked too early Permissions and APIs

`POST_NOTIFICATIONS` is requested immediately after sign-in with no explanation (`hooks/useNativeBack.js:72-85`). Policy asks for requests "in context (via incremental requests)". **Fix:** show a short reason first, at the first moment a notification is relevant.

W4 — Unused permission Permissions and APIs

`@capacitor/haptics` adds `VIBRATE` but nothing uses it. **Fix:** uninstall the plugin and re-sync.

W5 — No disclosure for voice recordings User Data

The mic request itself is fine (on tap). But recordings are stored with transcripts and sent to speech-to-text providers, and the app never says so at the point of use. **Fix:** one-time disclosure on first mic use.

W6 — Finance features need a declaration Financial Services

Ledger, invoices, payments, expenses and AI bill reading are financial features: "Any app that contains any financial features must complete the Financial features declaration form". Declare them as bookkeeping only.

W7 — Adults-only isn't enforced Families

18+ appears only in the privacy policy. Select 18+ in Target Audience and avoid anything that reads as child-directed.

W8 — Analytics could break your declarations Data safety section

PostHog is wired in but inactive in the current Android build (key is still a placeholder). Sentry runs only if `SENTRY_DSN` is set. If either is switched on, the Data Safety form and privacy policy must change in the same release.

W9 — Stale demo data for reviewers User Generated Content

The demo workspace is re-seeded only at server boot, so between boots it can hold leftovers from the public. Reviewers might see offensive text. Tied to C2.

W10 — Over-broad file sharing paths Device and Network Abuse

`res/xml/file_paths.xml` exposes `external-path "."`. The provider isn't exported, but narrow it to the folder actually used.

W11 — "WebView wrapper" review risk Spam, Functionality & UX

Reviewers sometimes reject apps that look like a wrapped website. Native push, mic, proximity sensor, App Links and bundled content are a strong defence — show them in the screenshots and description.

3. Data Safety form and privacy policy requirements

Data Safety form — data collected

Category › type	Source in the app	Required?	Purposes
Personal info › Name, Email, Phone number, User IDs	Account, OTP login, team	Phone required; email optional for members	App functionality, Account management, Developer communications
Personal info › Other info	CRM contacts (other people's names, phones, addresses), company GST	Optional	App functionality
Financial info › Other financial info	Invoices, payments, expenses, assets, AI ledger	Optional	App functionality
Messages › Other in-app messages	Comments, WhatsApp inbound messages	Optional	App functionality
Photos and videos › Photos	Avatars, bill photos	Optional	App functionality
Audio › Voice or sound recordings	Dex capture, signup interview (stored with transcripts)	Optional	App functionality
Files and docs	Uploads, Company Brain documents	Optional	App functionality
Calendar › Calendar events	<code>calendar_events</code>	Optional	App functionality
App activity › App interactions; Other user-generated content	Usage events, audit log, AI questions	Automatic	App functionality, Fraud prevention & security (+ Analytics if PostHog on)
App info and performance › Crash logs, Diagnostics	Only if Sentry is enabled	—	—
Device or other IDs	FCM token / Firebase Installation ID, session user agent	Automatic	App functionality (push), Security

- **Not collected:** location, health, device contacts, SMS/call logs, web history, installed apps.
- **Sharing:** if every provider (LLM, speech-to-text, email, SMS, storage, FCM) only processes data on your behalf, mark "not shared" — but name each in the privacy policy. WhatsApp sends via `wa.me` are user-initiated.
- **Security practices:** encrypted in transit — yes (HTTPS; cleartext only in debug). Users can request deletion — yes, give the web URL. Independent security review — no.

Privacy policy must add

1. The legal entity / developer name exactly as on the store listing, plus a contact address.
2. Every processor listed under C5, each with the data types it receives.
3. AI processing: what content and audio go to AI providers, when consent is asked, and that data is not used for training.
4. Specific retention periods for sessions, audit log, AI call logs, billing events, support tickets and push tokens.
5. What happens to work data a member created when they delete their account (does it stay with the employer's workspace?).
6. Both deletion paths: in-app (Settings › Account) and web (<https://www.decisionos.biz/delete-account>).
7. International transfers to US-based providers.
8. Public, non-geofenced, non-PDF URL, titled "Privacy Policy"; linked from Signup as well as Login and Settings.

4. Compliant areas

- **Target API:** targetSdk 36 meets the Target API Level policy.
- **No restricted permissions:** no location, SMS/call log, QUERY_ALL_PACKAGES, MANAGE_EXTERNAL_STORAGE, REQUEST_INSTALL_PACKAGES, exact alarms, foreground services, USE_FULL_SCREEN_INTENT, READ_MEDIA_*, CAMERA, accessibility or VPN. Camera is reached through the system picker (minimum-scope alternative).
- **Microphone:** RECORD_AUDIO requested at runtime, when the user taps the mic.
- **No ads:** no AD_ID, no ads SDK, no sale of data.
- **No downloaded code:** web content is bundled; external links open in other apps; no custom JavaScript interface.
- **Backups:** `allowBackup=false`; data-extraction rules exclude everything.
- **Deletion exists:** in-app and on the web, with confirmation and session revocation (incomplete — see C3).
- **Privacy policy reachable in-app:** linked from Login and Settings.
- **Push:** transactional only, no marketing.
- **Payments:** no in-app checkout, pricing page or payment link (apart from W1 wording).
- **Families:** not child-directed; store title "DecisionOS" within 30 characters, not ALL CAPS.

5. Everything to do before submitting

Work top to bottom. Groups A, B, L and P come from the policy PDF. Group R is the release mechanics from your own `docs/PLAY_STORE_PUBLISHING.md` and standard Play Console steps (not policy rules, but submission fails without them). Group V is the final check on a real release build.

#	Task	Fixes
A. Code — blockers (must ship in the submitted build)		
☐ A1	Add a "Report" control to every AI output: Dex replies, Company Brain answers, execution plans, bill-read results, signup interview. Store reports in a backend collection (prompt, output, user, time).	C1
☐ A2	Add an "AI can make mistakes" notice next to AI output.	C1
☐ A3	Require acceptance of the Terms of Service at signup and at invite acceptance, before any content can be created.	C2
☐ A4	Add "Report" on comments, tasks, decisions and notes; route reports to the admin portal with an action workflow.	C2
☐ A5	Add Report user / Block user (profile or member row). Required if @mentions or direct messages exist.	C2
☐ A6	Make the demo workspace read-only on the backend, or give each visitor a throwaway sandbox. Keep stable reviewer credentials.	C2, W9
☐ A7	Delete <code>device_tokens</code> server-side inside <code>delete_account</code> , and add it to <code>TENANT_COLLECTIONS</code> .	C3
☐ A8	For <code>sessions</code> , <code>audit_log</code> , <code>ai_calls</code> , <code>support_tickets</code> , <code>onboarding_drafts</code> , <code>crm_activities</code> , <code>billing_events</code> , login attempts: delete or anonymise per user on deletion, or set and disclose a retention period.	C3
☐ A9	Give an owner of a multi-member workspace a path to delete: transfer ownership, or delete the workspace.	C3
☐ A10	Move AI consent to the start of signup (clear disclosure + explicit "I agree") before the voice interview, speech-to-text and website analysis run.	C4
☐ A11	Link the Privacy Policy (and Terms) from the Signup screen.	C5
B. Code — strongly recommended before review		
☐ B1	Replace "or straight away on a bigger plan" (<code>aiLimit.js:43</code>) and "ask us to add seats" (<code>Team.js:452</code>) with neutral copy, or move upgrades to Play Billing.	W1
☐ B2	Exclude the <code>/admin</code> platform portal from the Capacitor build (build flag).	W2
☐ B3	Show a short explanation before the <code>POST_NOTIFICATIONS</code> prompt, at the first relevant moment instead of at sign-in.	W3
☐ B4	Run <code>npm uninstall @capacitor/haptics</code> then <code>npx cap sync</code> to drop <code>VIBRATE</code> .	W4
☐ B5	Add a one-time disclosure on first mic use: recordings are stored and transcribed by a third-party service.	W5
☐ B6	Narrow <code>res/xml/file_paths.xml</code> to the specific cache/sub-folder you use.	W10
☐ B7	Decide whether PostHog and Sentry are on in production; keep declarations in step with that decision.	W8

L. Legal documents and public web pages			
☐	L1	Rewrite the privacy policy with all 8 items in Section 3 (entity, processors, AI, retention, deletion, transfers).	C5
☐	L2	Publish it at a public, non-geofenced URL (e.g. <code>https://www.decisionos.biz/privacy</code>) and confirm it loads signed out.	C5
☐	L3	Write and publish Terms of Service / acceptable-use policy that defines banned content.	C2
☐	L4	Confirm <code>https://www.decisionos.biz/delete-account</code> is live, names the app, and works end to end for both phone-OTP members and email owners.	C3
☐	L5	Update <code>docs/PRIVACY.md</code> (Data Safety inventory) to include FCM, POST_NOTIFICATIONS and all processors.	C5
P. Play Console — App content declarations			
☐	P1	Privacy policy URL entered.	C5
☐	P2	Data Safety form completed exactly as in Section 3 (incl. deletion URL).	C5
☐	P3	Account deletion URL entered.	C3
☐	P4	Financial features declaration: bookkeeping only, no regulated financial services.	W6
☐	P5	Target audience and content: 18+ only.	W7
☐	P6	Content rating questionnaire: answer yes to users interacting/sharing content and to AI-generated content.	C1, C2
☐	P7	Ads declaration: "No, my app does not contain ads".	—
☐	P8	App access: provide working reviewer credentials (demo or dedicated reviewer account) with step-by-step login instructions.	C2
☐	P9	Health apps declaration: "not a health app" (leave/attendance is HR, not health).	—
R. Release mechanics and store listing			
☐	R1	Bump <code>versionCode / versionName</code> and build a signed release AAB (<code>./gradlew bundleRelease</code>) from a clean <code>npm run build + npx cap sync</code> .	—
☐	R2	Opt into Play App Signing (irreversible — see your publishing doc §3).	—
☐	R3	Set <code>ANDROID_APP_FINGERPRINT</code> to the Play App Signing SHA-256 so <code>assetlinks.json</code> verifies and App Links open the app.	—
☐	R4	Confirm production backend has <code>FIREBASE_SERVICE_ACCOUNT</code> set so push works for reviewers.	W11
☐	R5	Store listing: title (≤30 chars), short and full description that accurately describe features incl. AI and voice; no emojis, rankings, price claims or unattributed testimonials.	W11
☐	R6	Graphics: 512px icon (exists), 1024×500 feature graphic, phone screenshots showing native features.	W11
☐	R7	Category (Business or Productivity), contact email <code>support@decisionos.biz</code> , website.	—
☐	R8	Internal testing upload → read the pre-launch report and fix crashes/accessibility flags → closed testing → production. If yours is a personal developer account, Play requires a closed test with at least 12 testers for 14 days before production access.	—
V. Final verification on the release build			
☐	V1	Fresh install → signup: consent appears before any voice/AI step; ToS and privacy links visible.	C4, C2
☐	V2	Report an AI answer and a comment from inside the app; confirm both arrive in the admin queue.	C1, C2

☐	V3	Delete a test account (member, sole owner, owner-with-members); confirm in the database that no rows remain for that user, including <code>device_tokens</code> .	C3
☐	V4	Confirm <code>/admin</code> is unreachable, no upgrade wording appears, and the manifest has no VIBRATE.	W1, W2, W4

6. Open questions that may change verdicts

1. **Payments (W1):** can an individual pay at all, or is every plan sold to businesses under a contract? Does anything stop working in the Android app when a trial ends? (Today trial expiry only shows a label, but quotas do block AI calls.)
2. **Public pages:** are `decisionos.biz/privacy` and `/delete-account` live and reachable signed out? What legal entity name will be the Play developer?
3. **@mentions / direct messages:** do they exist? Either triggers the blocking requirement in C2.
4. **Demo workspace:** will it ship in the production build? If not, C2 drops to the in-workspace report requirement.
5. **Analytics:** will `REACT_APP_POSTHOG_KEY` and `SENTRY_DSN` be set in production?

This audit applies only the rules in the supplied policy PDF to the code as it stood on 8 October 2026. It is not legal advice. Play policy changes regularly; re-check the live Policy Center before each submission.